

Seguridad Física / Asignacion lab 6 (core)

La amenaza interna en BioSecure Labs

Análisis del Incidente

Descripción del Incidente: BioSecureLabs, empresa líder en la investigación biotecnológica sufrió un incidente de seguridad que comprometió gran parte de su información confidencial de investigación y desarrollo. Toda la actividad inusual se detectó en una computadora dentro del laboratorio principal por y durante la noche cuando se registraron transferencias de archivos hasta un servidor externo. Además, se desactivaron algunas cámaras de seguridad lo cual indica que los atacantes tuvieron acceso directo y sin restricciones dentro de las instalaciones a todos los archivos.

Eventos Clave:

- Actividad inusual y sospechosa durante la noche.
- Transferencias de archivos a servidores externos por fuera de las instalaciones de BIOSECURELABS.
- Desactivación de cámaras de seguridad en áreas clave a tiempos específicos.

Posibles Causas del Incidente:

1. **Empleado descontento:** Hay sospecha de que el ataque podría estar relacionado con un ex empleado que recientemente fue despedido, lo que indica una posible falta de revocación inmediata de sus permisos de acceso.
2. **Ingeniería social:** Los atacantes podrían haber manipulado a un empleado activo para obtener acceso físico a las instalaciones y los servidores.
3. **Vulnerabilidad en el sistema de seguridad:** La capacidad de desactivar las cámaras de seguridad sugiere que el sistema de monitoreo no tenía protocolos sólidos que impidieran su manipulación.

Potencial Impacto del Incidente:

- **Pérdidas financieras:** La divulgación de datos críticos de investigación puede afectar el valor y competitividad de la empresa.
- **Daño a la reputación:** La exposición de información sensible puede generar desconfianza en los socios y en la comunidad científica.
- **Implicaciones legales:** La filtración de datos de pacientes y propiedad intelectual puede llevar a demandas o sanciones regulatorias.

Vulnerabilidades de Seguridad Física Identificadas:

- **Control de acceso débil:** Falta de restricción de acceso nocturno y ausencia de autenticación multifactorial. (2FA)
- **Desactivación de cámaras de seguridad sin notificación:** No existen medidas que eviten la manipulación de cámaras.... (ONVIF- IP, etc)

- **Gestión deficiente de credenciales:** Las credenciales de un empleado despedido o el uso compartido de contraseñas sugieren una debilidad en la gestión de accesos.
 - **Monitoreo de actividad nocturna insuficiente:** La ausencia de alertas automáticas para actividades fuera de horario representa una brecha de seguridad.
-

Propuesta de Soluciones

1. Mejorar el Control de Acceso:

- **Autenticación multifactorial (MFA):** Implementar MFA para el acceso a áreas sensibles, como los laboratorios y la sala de servidores. Este sistema aumentará significativamente la seguridad al requerir más de un método de verificación.
- **Acceso restringido por horario:** Limitar el acceso a ciertas áreas en horarios laborales y restringir el acceso nocturno. Esto permitirá identificar inmediatamente intentos de acceso fuera de horario.
- **Credenciales biométricas:** Utilizar tecnología de reconocimiento facial o de huellas dactilares para áreas de alta seguridad, reduciendo el riesgo de acceso no autorizado por pérdida o préstamo de tarjetas de acceso.

2. Fortalecimiento de la Vigilancia:

- **Cámaras de seguridad con detección de manipulación:** Implementar cámaras que envíen alertas automáticas si se detecta desactivación o manipulación, con sistemas de respaldo que permitan una supervisión continua.
- **Sistema de vigilancia con IA:** Instalar cámaras de seguridad inteligentes con detección de movimiento y actividad inusual para generar alertas en tiempo real durante horarios no laborales.
- **Supervisión de los servidores de grabación:** Asegurar que los servidores de videovigilancia estén en áreas restringidas, accesibles únicamente para personal autorizado.

3. Gestión de Credenciales y Accesos:

- **Revocación inmediata de accesos tras el despido:** Asegurarse de que, una vez que un empleado deja la empresa, se eliminen o desactiven todas sus credenciales de acceso de inmediato.
- **Credenciales temporales rastreables para visitantes:** Implementar credenciales con tiempo limitado y acceso controlado, supervisando su uso en tiempo real.
- **Auditoría periódica de accesos:** Realizar auditorías de acceso mensuales para revisar y ajustar permisos de acceso de empleados y visitantes.

4. Gestión de Visitantes:

- **Registro de visitantes:** Implementar un sistema de registro digital para documentar la entrada y salida de todos los visitantes y empleados, con historial accesible para auditoría y monitoreo.

- **Acompañamiento obligatorio:** Asegurar que todos los visitantes sean acompañados por personal autorizado en todo momento, especialmente en áreas de investigación y desarrollo.
- **Restricción de acceso a áreas sensibles:** Definir zonas restringidas a las cuales no tengan acceso los visitantes, incluso si están acompañados.

5. Cultura de Seguridad y Capacitación:

- **Capacitación continua en seguridad:** Realizar sesiones de capacitación para los empleados sobre la importancia de la seguridad física y las amenazas de ingeniería social.
- **Conciencia de seguridad:** Fomentar una cultura de seguridad en la que los empleados se sientan incentivados a reportar comportamientos sospechosos o brechas de seguridad.
- **Políticas de uso y manejo de información confidencial:** Establecer y reforzar políticas sobre el manejo y acceso a información sensible, recordando la importancia de la protección de datos en la empresa.

6. Procedimientos de Respuesta ante Incidentes:

- **Simulacros de respuesta a incidentes:** Realizar simulacros regulares de respuesta ante ciberataques y violaciones de seguridad para evaluar la preparación de la empresa.
- **Equipo de respuesta rápida:** Designar un equipo especializado que pueda actuar rápidamente ante incidentes de seguridad física o cibernética.
- **Copias de seguridad frecuentes y aislamiento de datos sensibles:** Almacenar respaldos de datos críticos en ubicaciones separadas y protegidas, para facilitar la recuperación sin depender de la infraestructura comprometida.